

Penzzer IEC 62443-Aligned Industrial Protocol Fuzzing Evidence

Compliance and Technical Evidence Brief

Document type	Compliance and Technical Evidence Brief
Version	1.0
Date	11 May 2026
Owner	Penzzer OT Security Assurance

Primary audience

OT security teams, industrial asset owners, system integrators, industrial OEMs, GRC and procurement teams, and security assurance reviewers in Japan, EMEA, and North America.

Contents

1	Summary	3
2	Standards Coverage	4
3	Supported Protocols	5
4	Evaluation Scope	6
5	Test Categories Executed	7
6	Methodology	8
7	IEC 62443 Alignment Matrix	9
8	Evidence Package	10
9	Reported Metrics	11
10	Acceptance Criteria	12
11	Buyer Requirement Mapping	13
12	Scope of Claim	14
13	Independent Technical Review	15
14	Reference Sources	16
15	Document Control	17

1. Summary

Penzzer evaluates industrial control devices under malformed traffic, invalid state transitions, unauthorized protocol behavior, and resource stress, and produces reproducible evidence mapped to the IEC 62443 foundational requirement areas and to IPA's Cyber/Physical Security Framework (CPSF).

This document provides the technical and compliance evidence buyers need for OT security review, supplier qualification, and product security assessment. It is a standalone reference; it does not require a separate sales briefing.

1.1 Certification-readiness position

Penzzer does not claim IEC 62443 certification for the Penzzer product itself. Instead, Penzzer provides IEC 62443-aligned industrial fuzzing evidence that can support OT security review, supplier qualification, product security assessment, and certification-readiness activities.

Formal IEC 62443 product, component, system, or secure-development-lifecycle certification is issued by accredited certification bodies under recognized schemes such as ISASecure CSA, SSA, and SDLA. Penzzer evidence is structured as supporting technical material for internal assessors, customer audit teams, and external IEC 62443 / ISASecure assessment partners.

For Tier-1 engagements, an independent technical review may be included as part of the evidence package. The scope and reviewing laboratory are defined in the engagement test plan (see §13).

2. Standards Coverage

Penzzer's fuzzing evidence is mapped to the following frameworks:

Framework	Coverage
IEC 62443-4-2 (component requirements)	Foundational Requirements FR1–FR7
IEC 62443-4-1 (secure product development)	Supporting evidence for security verification and validation testing (SVV) and security defect / vulnerability management activities
IEC 62443-3-3 (system security requirements)	System-level mapping where assets are tested as part of a system
METI / IPA Cyber/Physical Security Framework (CPSF)	Relevant Layer 2 and Layer 3 checkpoints for cyber and cyber-physical risk in industrial environments
ISASecure CSA / SSA / SDLA	Supporting technical evidence that may assist assessment preparation, lab review, and remediation planning
METI OT security guidelines	Aligned with the supply-chain and operational-resilience expectations for critical infrastructure operators
JPCERT/CC ICS advisories	Findings include reproduction data suitable for coordinated disclosure where appropriate

2.1 IEC 62443 foundational requirement coverage

FR	Foundational Requirement	Penzzer Coverage
FR1	Identification and Authentication Control	Session and authentication fuzzing for protocols where authentication is defined (OPC UA, DNP3 Secure Authentication, BACnet/SC)
FR2	Use Control	Unauthorized command and function-code testing across all supported protocols
FR3	System Integrity	Malformed message, stateful, and boundary-value testing across all supported protocols
FR4	Data Confidentiality	Error-response inspection for operational data leakage
FR5	Restricted Data Flow	Protocol-boundary and routing tests for gateways and protocol converters
FR6	Timely Response to Events	Logging, alerting, and telemetry observation during abnormal protocol conditions
FR7	Resource Availability	Resource-exhaustion, recovery, and watchdog-behavior testing within safety limits

2.2 Security Level treatment

Penzzer evidence is mapped to IEC 62443 foundational requirement areas. Penzzer does not assign or certify IEC 62443 Security Levels (SL1–SL4). Where requested, findings and test evidence can be organized to support a buyer's internal SL-T / SL-A assessment or an external certification-body review.

3. Supported Protocols

The following industrial protocols are supported. Coverage is stated explicitly so buyers do not need to ask.

Protocol	Status	Notes
Modbus/TCP	Supported	Full function-code matrix, malformed and stateful coverage
EtherNet/IP (CIP)	Supported	Explicit and implicit messaging, CIP object fuzzing
PROFINET	Supported — scope dependent	DCP and selected cyclic / acyclic communication scenarios; RT / IRT scope confirmed during test planning
EtherCAT	Supported — scope dependent	Mailbox and selected process-data fuzzing scenarios; hardware-in-the-loop setup confirmed during test planning
OPC UA	Supported	Binary and HTTPS bindings, session and security-channel fuzzing
DNP3 (TCP and serial-over-TCP)	Supported	Includes Secure Authentication v5
BACnet/IP	Supported	Object and service fuzzing; BACnet/SC supported
CC-Link IE Field / IE TSN	Available by custom grammar onboarding	Common in Japanese factory automation; scope confirmed during test planning
CC-Link (classic)	Available by custom grammar onboarding	—
SLMP (Mitsubishi)	Available by custom grammar onboarding	MELSEC seamless message protocol
MELSOFT (Mitsubishi)	Available by custom grammar onboarding	—
FL-net (JEMA)	Available by custom grammar onboarding	—
Omron FINS	Available by custom grammar onboarding	TCP and UDP transports
Yokogawa Vnet/IP	Available by custom grammar onboarding	—
Keyence KV protocol	Available by custom grammar onboarding	—
HSE (Foundation Fieldbus HSE)	Supported	—
Vendor-specific protocols	Available by custom grammar onboarding	Lead time and scope confirmed during test planning

Status values used in this table: Supported; Supported — limited coverage; Available by custom grammar onboarding; Planned; Not currently supported. Buyers should confirm protocol scope in the test plan before campaign execution.

4. Evaluation Scope

4.1 Assets under test

Penzzer evaluates: PLCs, RTUs, I/O modules, industrial gateways, protocol converters, engineering workstations, HMIs, embedded industrial devices, industrial network appliances, and simulated or emulated industrial protocol targets.

Each asset record includes manufacturer, model, firmware version, hardware version, configuration, network role, enabled protocols, safety limits, reset and recovery procedure, and known test constraints.

4.2 Test environment

Testing is performed in a controlled OT test environment. Live production control systems are tested only with explicit written authorization and operational safety controls in place.

The test environment is documented in every engagement: network topology, zone and conduit assumptions, test host configuration, monitoring points, packet capture location, device logging method, power-cycle and reset access, safety boundary, operational constraints, and stop conditions.

5. Test Categories Executed

The standard evaluation model includes the following twelve protocol robustness categories. Each engagement documents which categories are applicable, executed, modified, or excluded based on protocol behavior, asset capability, safety constraints, and buyer-approved scope.

Category	Description
Malformed Packet Testing	Invalid lengths, headers, checksums, encodings, and message structures
Boundary Value Testing	Maximum, minimum, null, negative, overflow, and out-of-range field values
Illegal Function or Service Testing	Unsupported function codes, invalid service calls, reserved values
Stateful Protocol Testing	Invalid transitions, out-of-order sequences, invalid session state, replayed steps
Authentication and Session Testing	Invalid credentials, malformed session tokens, expired sessions, unauthorized reuse
Unauthorized Command Testing	Command execution attempts outside expected authorization or state
Timing and Rate Testing	Bursts, delays, jitter, replay timing, polling disruption, high-rate traffic
Fragmentation and Reassembly Testing	Split messages, truncated messages, oversized fragments, reassembly abuse
Discovery and Enumeration Testing	Broadcast, multicast, and discovery-message robustness
Resource Exhaustion Testing	CPU, memory, connection table, session, and buffer pressure within safety limits
Recovery Testing	Behavior after crash, hang, communication loss, watchdog reset, reboot
Logging and Alerting Testing	Detection and telemetry generation under abnormal protocol conditions

6. Methodology

Phase 1 — Scope Definition

Protocols, asset under test, firmware version, safety boundaries, test categories, expected normal behavior, stop conditions, evidence requirements, severity model, and pass/fail criteria are agreed in writing before testing begins.

Phase 2 — Baseline Characterization

Expected protocol traffic, device response behavior, normal polling cycle, normal CPU and memory state, expected logs, expected alarms, expected control behavior, and recovery procedure are recorded.

Phase 3 — Campaign Preparation

Seed corpus, protocol grammar or state model, mutation strategy, target service inventory, authentication or session material, rate limits, safety limits, and monitoring and logging tooling are prepared.

Phase 4 — Campaign Execution

Campaigns are separated by protocol, target asset, and test category so findings are attributable.

Phase 5 — Monitoring

Network traffic, device responses, protocol errors, service availability, control behavior, process simulation state, device logs, CPU and memory usage, watchdog behavior, and restart and recovery behavior are observed.

Phase 6 — Triage

Observations are classified as Confirmed Finding, Safety-Critical Finding, Availability Finding, Protocol Robustness Finding, Logging or Detection Gap, Expected Behavior, False Positive, or Out of Scope.

Phase 7 — Replay and Reproducibility

Each confirmed finding includes protocol, target asset, firmware version, test category, payload or message sequence, preconditions, timing details, expected and observed behavior, evidence artifacts, recovery steps, reproducibility status, and IEC 62443 FR mapping.

Phase 8 — Reporting

The final report contains executive summary, scope, environment, safety controls, methodology, IEC 62443 and IPA CPSF mapping tables, protocol and category coverage summaries, confirmed findings, severity model, reproducibility evidence, recovery results, logging observations, limitations, recommendations, and an artifact index.

7. IEC 62443 Alignment Matrix

Penzzer Evidence Area	IEC 62443 FR	CPSF Reference	Example Evidence
Malformed message handling	FR3 System Integrity	L2 / L3 cyber–physical integrity	Device rejects malformed input without crash or unsafe state
Unauthorized command testing	FR2 Use Control	L2 access and use control	Invalid command rejected or fails safely
Session and authentication fuzzing	FR1 IAC	L2 identification and authentication	Invalid session state does not grant access
Protocol boundary testing	FR5 Restricted Data Flow	L2 / L3 communication boundary	Messages do not cross unintended boundaries
Error-response review	FR4 Data Confidentiality	L2 information protection	Errors do not disclose sensitive operational detail
Logging and alerting review	FR6 Timely Response	L2 detection	Abnormal traffic produces logs, alerts, or telemetry
Resource exhaustion testing	FR7 Resource Availability	L3 availability and resilience	Device maintains availability or recovers within defined limits
Recovery testing	FR3 / FR7	L3 resilience	Device returns to expected operation after fault
Stateful protocol fuzzing	FR2 / FR3	L2 / L3 integrity and use control	Invalid state transitions do not trigger unsafe behavior

8. Evidence Package

Every engagement delivers the following package.

Evidence Item	Delivered	Purpose
Test plan	Standard	Scope and acceptance criteria
Asset inventory	Standard	Tested hardware, software, firmware
Protocol inventory	Standard	Tested services and communication paths
Network topology	Standard	Test environment and boundaries
Safety controls	Standard	Operational constraints and stop conditions
Baseline behavior record	Standard	Comparison against abnormal behavior
Fuzz category coverage	Standard	Methodology coverage
Execution logs	Standard	Test execution record
Packet captures	Standard	Technical replay and review
Device logs	Standard	Root-cause and detection review
Confirmed findings	Standard	Actionable results
Replay artifacts	Standard	Reproducibility
Recovery evidence	Standard	Resilience and availability behavior
IEC 62443 and IPA CPSF mapping	Standard	Compliance review
Limitations	Standard	Scope clarity
Independent technical review	Available for Tier-1 by default; available on request for other tiers	Third-party technical assurance (see §13)

9. Reported Metrics

Every report contains the following metrics with concrete values.

Metric	Description
Protocol Coverage	Protocols, services, function codes, objects, and commands tested
State Coverage	Protocol states and transition paths exercised
Message Coverage	Number and classes of messages generated
Mutation Coverage	Mutation strategies and field categories exercised
Unique Confirmed Findings	Reproducible findings with evidence
Crash Count	Reproducible device, service, or process crashes
Hang Count	Reproducible nonresponsive states
Recovery Time	Time to return to expected operation
Manual Recovery Requirement	Whether manual reset, reboot, or intervention was required
Availability Impact	Service degradation or loss of communication
Logging Coverage	Whether abnormal behavior was logged or alerted
Triage Confirmation Rate	Confirmed findings divided by candidate anomalies after triage
Reproducibility Rate	Confirmed findings reproducible by replay
Safety Impact Classification	Whether the finding may affect control, view, protection, or availability

9.1 Reference campaign results

The following are aggregate metrics from Penzzer's internal reference test suite. Engagement-specific results are always reported per asset.

Reference Metric	Value
Protocols covered in reference suite	16+
Devices tested in reference suite	51+ devices across 15+ vendors
Total messages generated per campaign (median)	10M+
Mean time to first confirmed finding	4–24 hours
Reproducibility rate (reference suite)	85–94%
Triage confirmation rate (reference suite)	60–79%
Mean recovery time after availability finding	Under 10 seconds

A redacted sample report may be made available as Appendix A on request.

10. Acceptance Criteria

A completed evaluation meets the following criteria:

1. Asset under test is identified by manufacturer, model, and firmware version.
2. Tested protocol scope is explicitly documented.
3. Test environment and safety boundary are documented.
4. Baseline normal behavior is captured.
5. The applicability and execution status of each protocol robustness category is documented; omissions are explained.
6. Execution logs and packet captures are retained.
7. Confirmed findings are separated from anomalies and false positives.
8. Recovery behavior is recorded for every availability-impacting finding.
9. Findings are mapped to IEC 62443 FRs and IPA CPSF function categories.
10. The report includes limitations and out-of-scope items.

11. Buyer Requirement Mapping

Buyer Requirement	Penzzer Response
Supplier must support IEC 62443 security review	Evidence is structured as supporting technical material for internal assessors and external IEC 62443 / ISASecure assessment partners
Product must demonstrate robustness against network attacks	Twelve test categories covering malformed traffic, state violations, unauthorized commands, and resource stress
Testing must support asset-owner risk assessment	Report includes asset, protocol, topology, safety boundary, and reproducibility evidence
Findings must be actionable	Each finding includes replay steps, evidence, affected asset, and recovery details
Testing must support certification activities	Mapping to IEC 62443 FRs, IPA CPSE, and ISASecure CSA/SSA/SDLA structure
Availability and recovery must be evaluated	Crash, hang, recovery, and resource-availability metrics included
Evidence must be auditable	Logs, packet captures, environment details, and artifact index included
Findings must be suitable for coordinated disclosure	Reproduction data is structured for JPCERT/CC and equivalent CSIRTs

12. Scope of Claim

This document is a technical evidence brief, not a certification artifact. It does not represent IEC, ISA, or ISASecure certification, nor any accredited certification-body assessment. Penzzer evidence may be submitted as supporting technical material to such schemes; the certification decision is made by the accredited body.

13. Independent Technical Review

For Tier-1 engagements, Penzzer may include an independent technical review as part of the evidence package. Independent review is also available for other engagements by mutual agreement.

The review may be performed by a mutually agreed external OT security laboratory, certification-preparation partner, or qualified industrial security assessor. The purpose of the review is to provide third-party assurance over the test plan, executed scope, evidence quality, finding reproducibility, and standards-alignment mapping.

The independent review may deliver: reviewed test plan, environment description, asset and protocol scope, executed category summary, confirmed findings summary, IEC 62443 alignment summary, limitations, and a signed technical review letter.

Important

Unless expressly issued by an accredited certification body under a recognized certification scheme, the independent review letter does not constitute IEC 62443 certification, ISA approval, or ISASecure certification.

14. Reference Sources

ISA/IEC 62443 Series of Standards

<https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards>

IEC 62443 overview and foundational requirements

<https://syc-se.iec.ch/deliveries/cybersecurity-guidelines/security-standards-and-best-practices/iec-62443/>

ISASecure IEC 62443 Conformance Certification

<https://isasecure.org/>

ISASecure ICSA Certification

<https://isasecure.org/certification/iec-62443-icsa-certification>

ISA/IEC 62443 Cybersecurity Certificate Program

<https://www.isa.org/certification/certificate-programs/isa-iec-62443-cybersecurity-certificate-program>

IPA Cyber/Physical Security Framework (CPSF)

<https://www.ipa.go.jp/security/economics/cpsf.html>

METI Cybersecurity Guidelines for Industrial Automation

<https://www.meti.go.jp/policy/netsecurity/>

JPCERT/CC ICS Security

<https://www.jpcert.or.jp/english/cs/ics.html>

15. Document Control

Owner

Penzzer OT Security Assurance

Reviewers

Product Security, OT Security Engineering, Legal, Compliance

Review cycle

Quarterly, or upon material changes to IEC 62443 positioning, IPA CPSF revisions, supported protocol scope, or certification scheme requirements.